Information Assurance and Security – ACIT4630

Iman Anooshehpour
Week 4

BRITISH COLUMBIA
INSTITUTE TECHNOLOGY

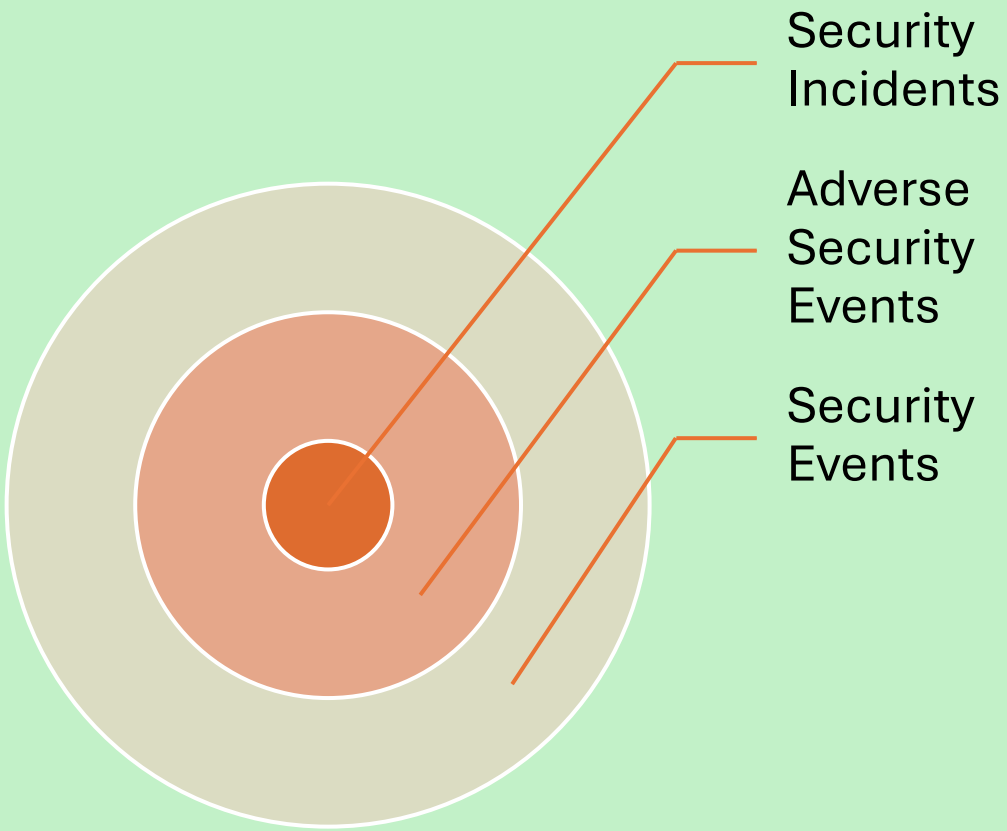
BCIT™

Today's Learning Outcome

1. Security incident identification & response process
2. Log tampering
3. Logging laws
4. Different backup approaches

Incident Identification

- Are all security events considered incidents?
- How do we identify a security incident?
- How are the identified incidents assigned severity ratings?



Security Events

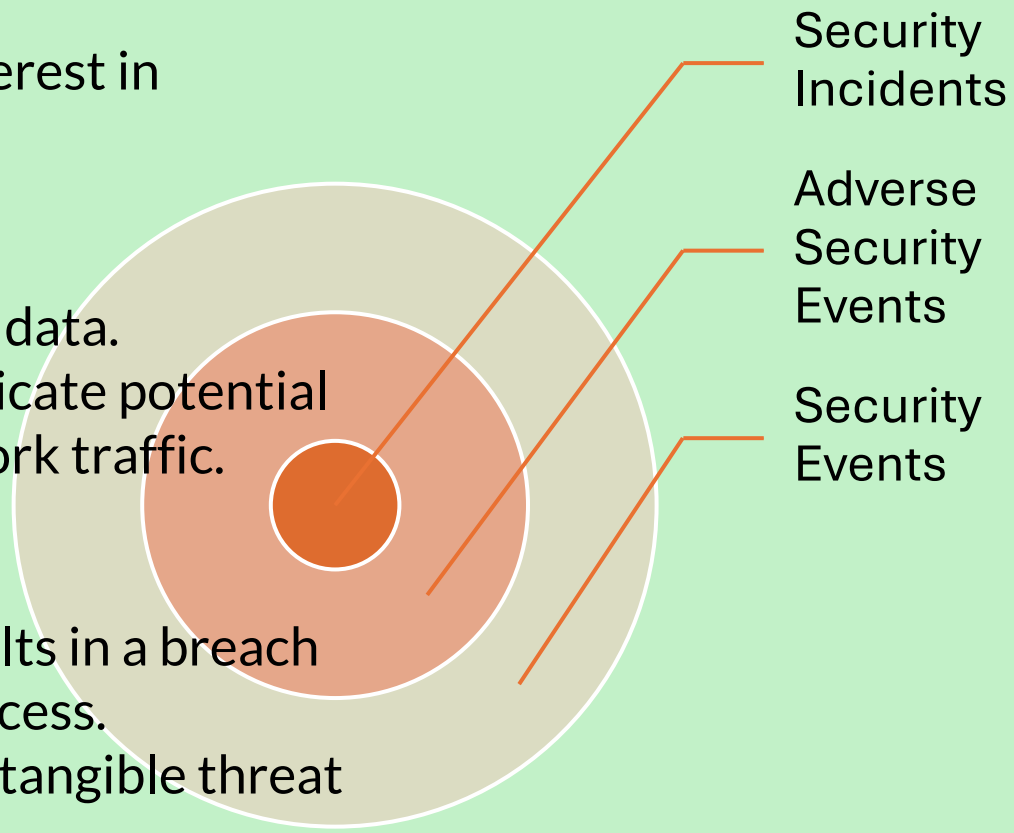
- Any observable occurrence within a system or network.
- Not necessarily harmful; could be routine actions like a user login or file access.
- Only flagged if they deviate from the norm or are of interest in security monitoring.

Adverse Security Events

- Events that negatively affect the security of systems or data.
- These might not always lead to significant harm but indicate potential issues, such as failed login attempts or suspicious network traffic.

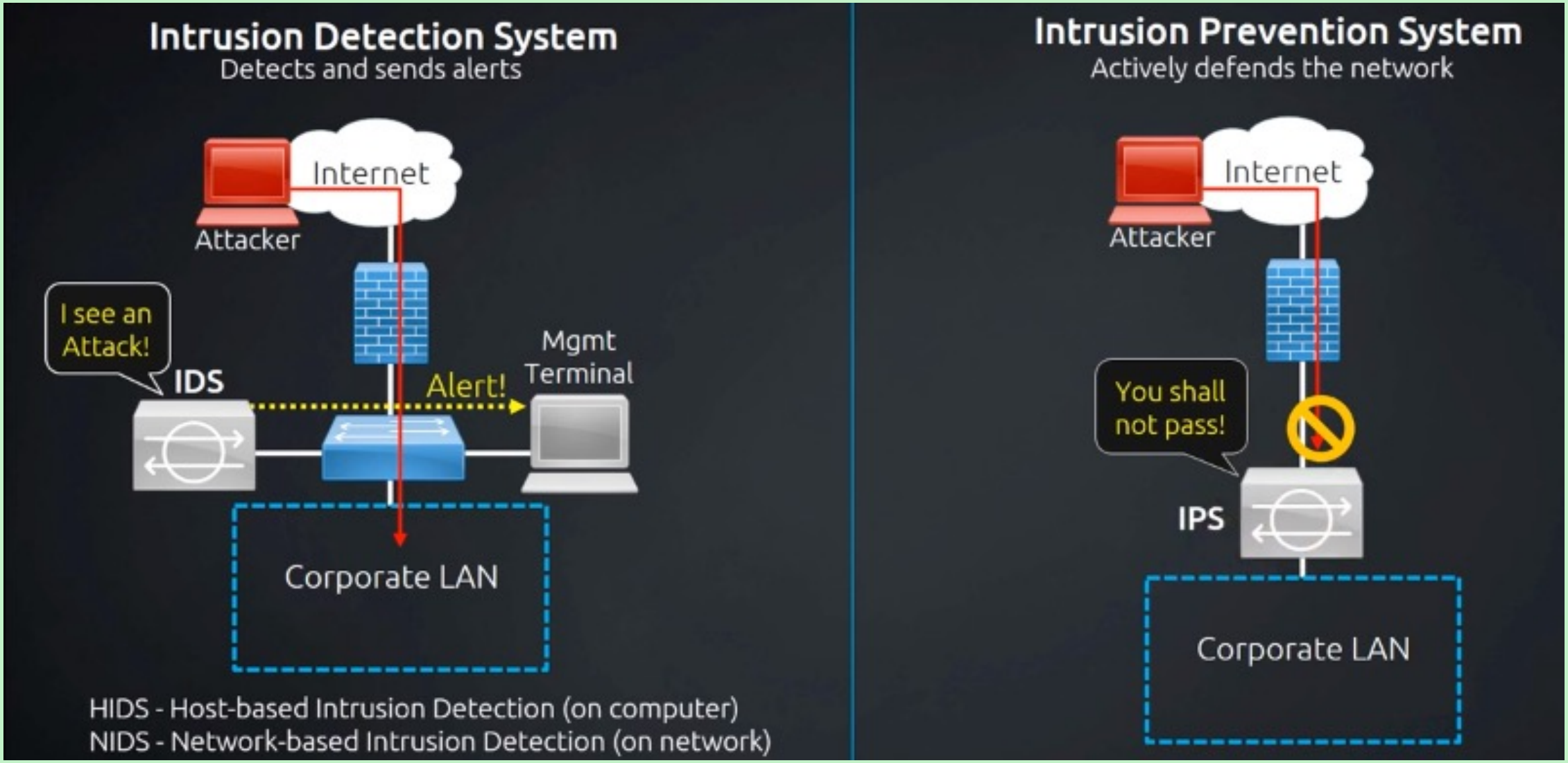
Security Incidents

- A confirmed event or series of adverse events that results in a breach of security policy, such as data theft or unauthorized access.
- Incidents require immediate action as they represent a tangible threat to the confidentiality, integrity, or availability of assets.



Incident Data Sources

- IDS/IPS
- Firewalls
- Authentication systems
- Integrity monitors
- Vulnerability scanners
- System event logs
- NetFlow records
- Anti-malware packages



Source: Intrusion Detection and Intrusion Prevention Systems

SIEM (Security Information and Event Management)

"A solution that helps organizations detect, analyze, and respond to security threats before they harm business operations"

Centralized Log Management

All system send logs directly to the SIEM platform.

AI-Driven Threat Detection

Correlate and analyze log in data that could indicate a malicious activities.

Syslog

"The de facto standard for sending and receiving log messages between applications, systems and devices on Linux."

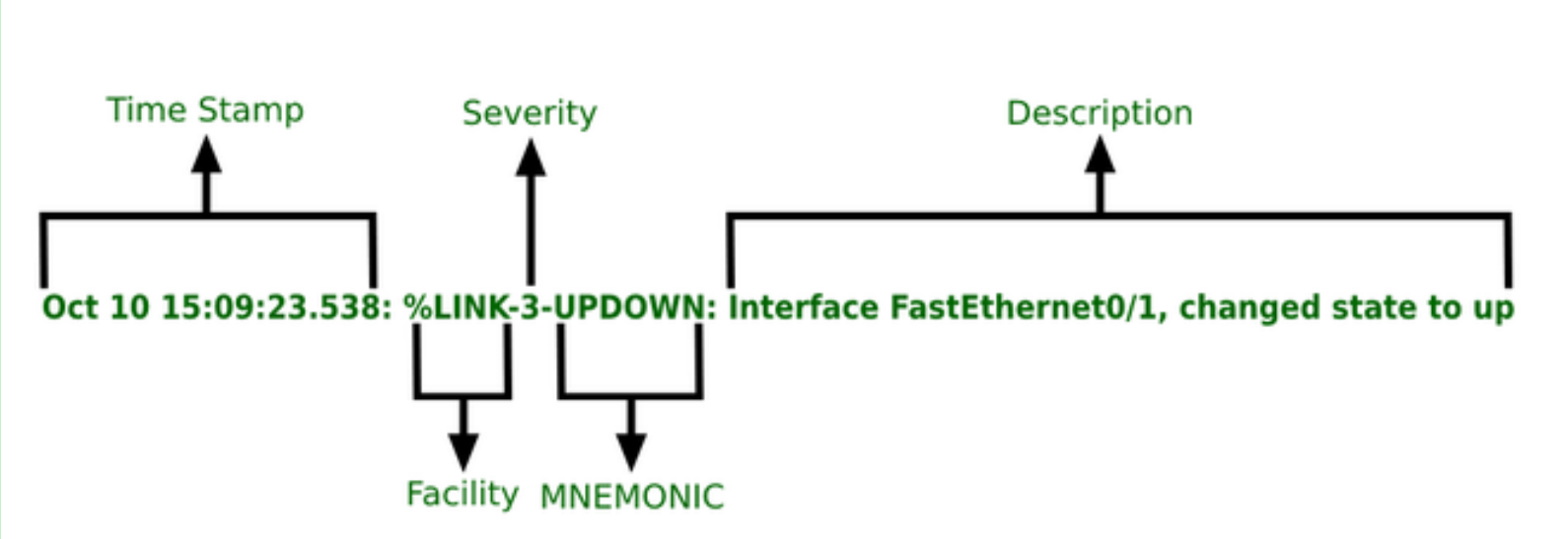


Image source: What is Syslog server and its working?

Determining **Incident Severity**

Assessment Based on the CIA Triad:

Confidentiality: Does the incident expose sensitive information to unauthorized parties?

Integrity: Are there alterations or potential damage to the accuracy and completeness of data?

Availability: Is there any disruption in access to critical systems or data?

Incident Severity Levels 1-5

Severity	Description
SEV 1	A critical incident that affects a large number of users in production.
SEV 2	A significant problem affecting a limited number of users in production.
SEV 3	An incident that causes errors, minor problems for users, or a heavy system load.
SEV 4	A minor problem that affects the service but doesn't have a serious impact on users.
SEV 5	A low-level deficiency that causes minor problems.

Article: Incident Severity Levels 1-5 Explained

Data Sensitivity Focus:

- **PII**: Personally identifiable information
- **PHI**: Personal health information
- **SPI**: Sensitive personal information (e.g., genetic or sexual orientation data)
- **PCI**: Payment card industry data

- Severity Assessment Criteria:
  - Downtime, Recovery Time, Data Integrity Breach, Economic Impact, Business Processes Criticality
- Adapt criteria to specific needs and environment
- Apply consistent criteria for effective incident management and resource allocation

Urgency \ Impact	High	Medium	Low
High	1	2	3
Medium	2	3	4
Low	3	4	5

Image source: ISO 27001 A.16 – How to handle security incidents

NIST Incident Response

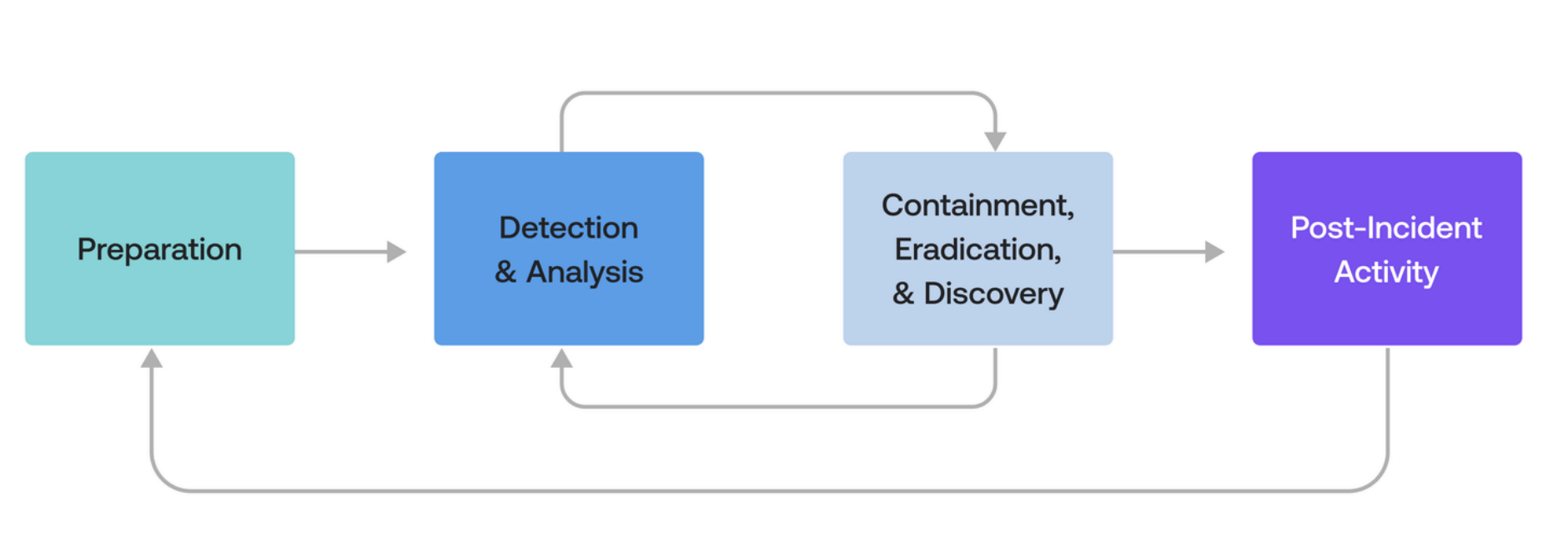


Image source: NIST Incident Response: Your Go-To Guide to Handling Cybersecurity Incidents

Choosing a Containment Strategy

- Potential damage to and theft of resources
- Need for evidence preservation
- Service availability (e.g., network connectivity)
- Time and resources needed to implement the strategy
- Effectiveness of the strategy
  - (e.g., partial containment, full containment)
- Duration of the solution
  - (e.g., **emergency workaround** to be removed in four hours, **temporary workaround** to be removed in two weeks, **permanent solution**).

Containment Techniques

- **Segmentation**: Dividing networks into logical segments.
- **Isolation**: move compromised systems to a network completely disconnected from the main network.
- **Removal**: Completely disconnects impacted systems from any network to cut off the attacker's access.

Incident Eradication & Recovery

- Eradication Goals:
  - Remove incident traces.
  - Secure user accounts, system configs.
- Recovery Objectives:
  - Restore normal operations.
  - Simultaneous activities with eradication.
- Rebuild systems to prevent backdoors.
- Media Sanitization Techniques: Clear, Purge, Destroy

Validation Process

- Verify the secure configuration of every system
- Run the vulnerability scans
- Perform account and permission reviews
- Verify that systems are logging and communication to the SIEM

Post-mortem Best Practices

- Do take responsibility
- Do gather information
- Do define clear owners
- Do use a consistent template

- Don’t assign blame
- Don’t procrastinate
- Don’t be vague
- Don’t lose focus

Log Tampering

- Why would malicious users/malwares want to tamper with logs?
- What are some processes mentioned in this article that hackers might do for log tampering?
- From this list look up some Event IDs that might indicate log tempering

		to High	
1102	517	Medium to High	The audit log was cleared
4621	N/A	Medium	Administrator recovered system from CrashOnAuditFail. Users who are not

Log Shredding In Linux

```
shred -vfz [/file/system/path]
```

According to the `man` page, some of the [OPTIONS] you can use with `shred` are:

- `-n`, --iterations=N
  Instead of the default (3) times, overwrite the data N times.
- `-z`, --zero
  Add a final overwrite with zeros to hide shredding.
- `-f`, --force
  Force the permissions to allow writing if necessary.
- `-v`, --verbose
  Show progress in detail.
- `-u`, --remove
  Truncate and remove file after overwriting.

Logging Laws

- **Law of Collection**:

  "Do NOT collect/generate log data that you NEVER plan to use."

- **Law of Retention**:

  "Retain log data for as long as it is conceivable that it can be used—or longer if prescribed by regulations."

- **Law of Monitoring**:

  "Log all you can (which is as much as possible), but alert only on what you must respond (which is as little as possible)."

Logging Laws (Cont.)

- **Law of Availability**:

  "Don't pay to make your logging or monitoring system more available than your business systems."

- **Law of Security**:

  "Don't pay to protect your log data more than you pay to protect your critical business data."

- **Law of Constant Changes**:

  "Logs sources, log types, and log messages change."

Backups

- How are **full**, **differential**, and **incremental** backups different?
- How many backup files are needed for recovery from each kind of backup?
- How would you sort different kinds of backups according to following criteria:
  - Storage capacity, Recovery speed, Backup time